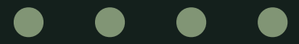
THE CHALLENGE · ACCESS THE ADMINISTRATOR ACCOUNT

One admin account. Two ways in.

PASSWORD LOGIN



Email + password

The admin’s password remains unknown.

GOOGLE LOGIN

IDENTITY STATEMENT

Account ID

“Here is who is signing in.”

A statement sent to the site

The site reads the account ID.

THE WEAKNESS

On the “legacy” path, **the site did not verify the signature.**

DEAD ENDS · CHANGING THE ROLE IS NOT ENOUGH

Writing “admin”…
The promotion was declined.

	QUESTION TESTED	WHAT THE SERVICE RETURNED
01	Add “role: admin” Can we grant ourselves privileges?	× The account remains a regular user.
02	Keep the email, change the ID Does the site identify an account by its email?	× A different account is created.
03	Keep the same “sub” ID Is this what selects the account?	✓ The same account is found.

`sub` The Google account ID.
The role is then read from the stored account.

THE TAKEAWAY

We needed to find **the real admin account’s ID.**

THE BREAKTHROUGH · THE CLUE WAS IN THE FOOTER

The ID could be found.
The site treated it as a secret.

01

The footer

Tech Corp Chandler

A Gmail contact address

PIED DE PAGE · INDICE REPRÉSENTÉ

A clue recorded in the journal,
in the homepage footer.

02

Looking up the account

Google People API

Using a test Google session

Here, the address leads to an ID.

03

The right ID

1034…4574

GAIA ID / sub · abbreviated

To place in the fabricated statement.

THE TAKEAWAY

The breakthrough: **look up the identity** instead of guessing a password.

THE RESULT · SOLVE RECORDED AT 21:25

The right ID.
An administrator session.

Fabricated identity statement → Existing account found → ADMIN
ROLE OF THE MATCHED ACCOUNT

EXCERPT FROM THE SAVED WRITE-UP · TRANSCRIPTION

socialLogin	**memberId: 1 · role: admin**
/api/flag	**flag returned**

The /api/admin/flag route was a decoy: it returned 404 even when signed in.

`BA26{sub_is_not_a_secret_but_treating_it_like_a_password_is}`

THE TAKEAWAY

Verify **the proof of identity**, don’t just read the ID.